

SOC Investigation Report: Slow & Low IoT DDoS Evasion

Course: AI for Cybersecurity — CSA412

University: Future University in Egypt

Student ID: 20234029

Date: 2026-04-27

Section 1 — Executive Summary

This report details the investigation of a sophisticated 'Slow & Low' DDoS attack orchestrated by a botnet. Unlike traditional volumetric DDoS attacks that attempt to overwhelm the target with sheer traffic volume, a Slow & Low attack operates below standard detection thresholds. It deliberately sends requests at a minimal rate and keeps connections open for extended periods, effectively exhausting server resources (like connection pools) without triggering standard rate-limiting alarms.

The scenario represents a critical danger to modern infrastructure, particularly IoT environments, because standard rule-based Intrusion Detection Systems (IDS) often fail to detect such evasion tactics, leading to silent service degradation or outages.

Section 2 — Attack Vector Summary (Red Team Analysis)

The attack leverages the 'Slow & Low' DDoS concept, which establishes multiple connections and trickles data to hold them open as long as possible.

- **Attack Rate Formula:** $(20223617 \% 100) / 100 = 0.17 \text{ pkts/sec}$
 - **Multi-phase Structure:** Probe (0-20%) → Sustain (20-80%) → Cool (80-100%)
 - **Botnet:** 8 devices distributed across 3 subnets.
 - **Slowloris Traits:** Small TCP window sizes (512-1024 bytes) and long flow durations (8-15s).
- **Why it evades traditional IDS thresholds:** By maintaining a minimal packet rate and blending in with normal traffic, the attack avoids volumetric triggers and rate-limiters entirely.

Section 3 — Blue Team ML Model Evaluation

To counter the evasion tactics, Machine Learning models were deployed to analyze flow features.

Metric	Random Forest	Logistic Regression
Accuracy	> 99%	~ 95%
Precision	> 99%	-
Recall	> 99%	~ 90%
F1-Score	> 99%	~ 91%

The Random Forest classifier outperformed Logistic Regression significantly. Crucially, the **Feature Importance** analysis revealed that the top features contributing to detection were *rolling_rate_mean*, *flow_density_30s*, and *inter_arrival_time*. These temporal features capture the sustained, low-intensity nature of the attack.

Section 4 — Rule-Based vs AI Comparison

A Rule-Based IDS set at a threshold of 5.0 pkts/s yielded a Recall of $\approx 0\%$. This is a complete failure to detect the threat.

Why Rule-Based Fails: The attack was engineered to run at 0.17 pkts/sec. Hardcoded threshold rules only flag volumetric anomalies. The IDS never triggers because the traffic blends in with normal behavior.

Why AI was Necessary: AI models, utilizing rolling windows and time-series feature engineering, evaluate the *behavior* of the flow over time. This behavioral analysis is essential for identifying Slow & Low attacks.

Section 5 — Attacks That Bypassed AI

While the AI models achieved excellent overall performance, certain edge cases still bypassed detection:

- **The Cool-down Phase:** During the final phase of the attack (intensity=0.3), detection confidence dropped significantly.
- **Bursting Packets:** A 10% probability of bursting packets was introduced to briefly confuse the model.
- **Reasoning:** Feature rolling windows need a 'warm-up' period to accumulate sufficient data. Rapidly oscillating behavior exploits this window before the rolling features stabilize.

Section 6 — Conclusion & Recommendations

Based on the investigation findings, the following actions are recommended to secure the IoT infrastructure:

1. **Deploy behavior-based AI detection:** Transition to ML-driven detection for IoT environments.
2. **Implement time-series anomaly detection:** Focus on temporal metrics to identify low-profile malicious flows.
3. **Use SHAP for model explainability:** In a production SOC, integrate SHAP to provide transparent insights into flagged traffic.